

VPC Service Controls 基本教學課程 II - 排解輸出違規問題

來源：<https://codelabs.developers.google.com/codelabs/vpc-sc-beginnerlab-2?hl=zh-tw>

步驟數：8

在本研究室中，我們會建立 VPC Service Controls 範圍，並用來保護專案。接著，我們會叫用 VPC Service Controls 的輸出違規事項，並建立輸出規則，逐步解決拒絕這個情形的程序。完成這個研究室之後，您會更加瞭解如何運用 VPC Service Controls 保護資源。

目錄

1. [1. 簡介](#)
2. [2. 設定和需求](#)
3. [3. 建立 Storage Bucket 和 Object](#)
4. [4. 保護 Cloud Storage API](#)
5. [5. 確認 Cloud Storage API 已受到保護](#)
6. [6. 排解清單遭拒問題。](#)
7. [7. 清除所用資源](#)
8. [8. 恭喜！](#)

1. 簡介

[VPC Service Controls \(VPC-SC\)](#) 是 Google Cloud 的機構層級安全控管機制，可協助企業客戶降低資料竊取風險。VPC Service Controls 提供零信任式的多租戶服務存取方式，可讓客戶在從網際網路和其他服務連至多租戶服務時，將存取權限制為僅有獲授權的 IP、用戶端情境及裝置參數可存取，藉此減少有意和無意的損失。如 [VPC Service Controls 基本教學課程 I](#) 所述，您可以使用 VPC Service Controls 建立 perimeter，保護您明確指定的服務資源和資料。

如果您尚未完成 [VPC Service Controls 基本教學課程 I](#)，請先完成該課程，為本教學課程進行必要的事前設定。

本教學課程的目標如下：

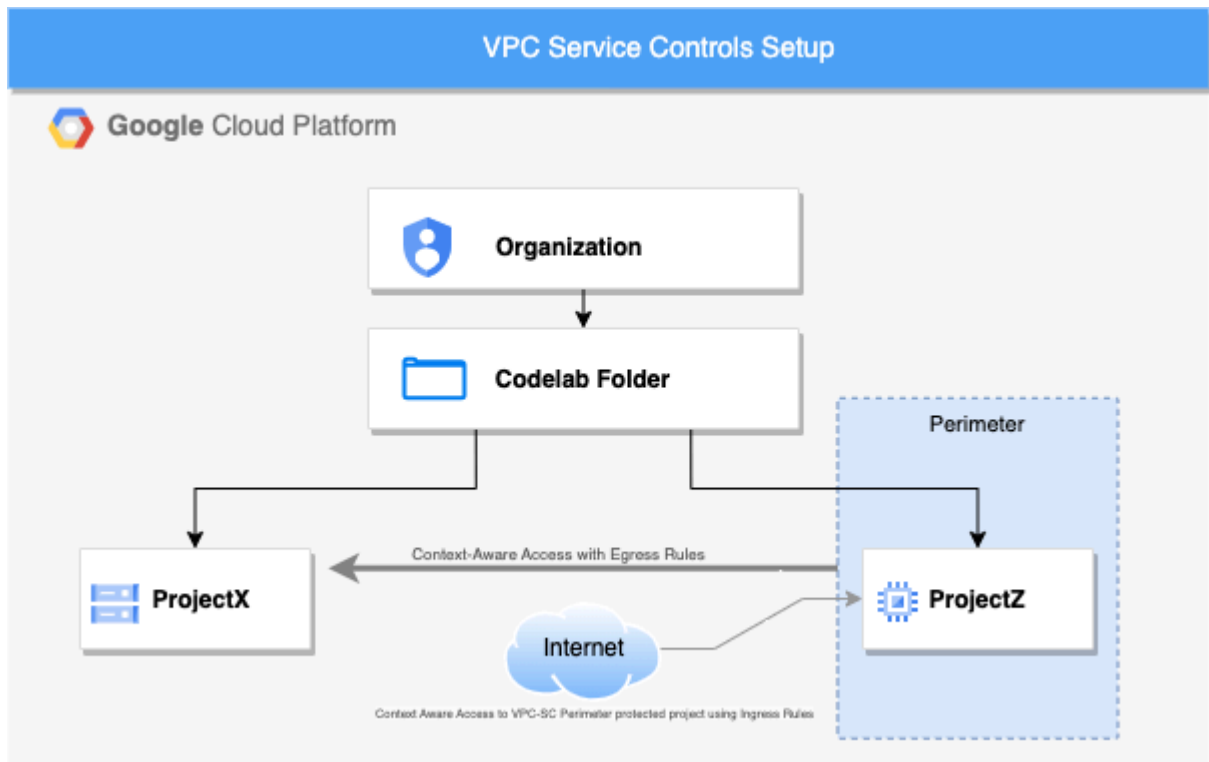
- 瞭解 VPC Service Controls 的基本概念
 - 更新服務範圍並使用模擬測試模式進行測試
 - 使用 VPC Service Controls 保護兩項服務
 - 排解從 Cloud Storage 列出物件時發生的 VPC Service Controls 輸出違規問題
-

步驟 2 · 約 10 分鐘

2. 設定和需求

本教學課程需要符合下列先決條件：

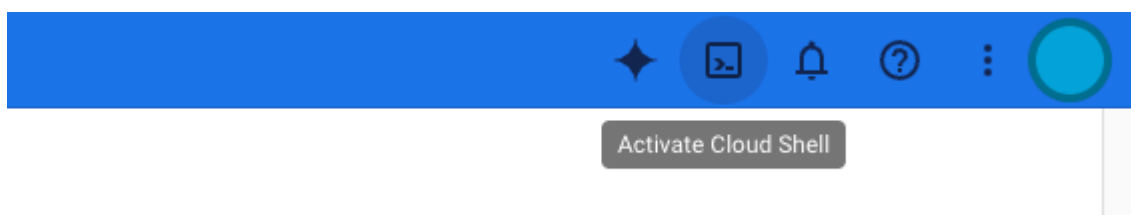
- GCP 機構。
- 機構下的資料夾。
- 位於資料夾下同一個機構中的 2 個 GCP 專案。
- 組織層級的[必要權限](#)。
- 兩個專案的帳單帳戶。
- [VPC Service Controls 基本教學課程 I](#)：設定 VPC Service Controls 和 Access Context Manager。



資源設定

1. 按照 [VPC Service Controls 基本教學課程 I](#) 的「資源設定」一節所述設定資源
 2. 確認您具備管理 Cloud Storage 的必要[權限](#)。
 3. 在本教學課程中，我們將開始使用 CLI，而非 Cloud 控制台。在其中一種開發環境中設定 gcloud CLI：
- **Cloud Shell**：如要使用已設定 gcloud CLI 的線上終端機，請啟用 Cloud Shell。

按一下雲端控制台右上角的圖示，啟用 Cloud Shell。工作階段可能要幾秒鐘的時間才能初始化。詳情請參閱 [Cloud Shell 指南](#)。



- **本機殼層**：如要使用本機開發環境，請[安裝並初始化](#) gcloud CLI。

費用

您必須在 Cloud 控制台中啟用帳單功能，才能使用 Cloud 資源/API。完成這個程式碼研究室的費用不高，甚至可能完全免費。如要關閉資源，避免在本教學課程結束後繼續產生費用，請刪除您建立的資源或專案。Google Cloud 新使用者可參加價值 \$300 美元的[免費試用計畫](#)。

只有 VM 執行個體和 Cloud Storage 物件會產生費用。您可以在[定價計算機](#)中查看 VM 執行個體的預估費用。如要瞭解 Cloud Storage 的預估費用，請參閱[這份價格清單](#)。

3. 建立 Storage Bucket 和 Object

如先前所述，我們將沿用[上一個教學課程](#)中建立的資源。因此我們將繼續建立 Cloud Storage 值區。在本教學課程中，我們將開始使用 gcloud CLI，而非控制台。

1. 在 Google 控制台中選取 ProjectX。在本專案中，我們將[建立 Storage Bucket](#) 和物件。
2. 請執行下列指令，確保 Cloud Shell 使用 ProjectX：

```
gcloud config set project PROJECT_ID
```

3. 在開發環境中執行下列指令：

```
gcloud storage buckets create gs://BUCKET_NAME --location=us-central1
```

值區名稱在全域範圍內都不可重複。如要進一步瞭解如何為 bucket 命名，請參閱[這份文件](#)。

4. 建立儲存空間物件，以便從位於 ProjectZ 的 VM 執行個體讀取該物件。我們會建立 .txt 檔案。

```
nano hello.txt
```

在文字檔中新增任何內容。

5. 將物件上傳至 bucket。

```
gcloud storage cp /home/${USER}/hello.txt gs://BUCKET_NAME
```

6. [列出](#)物件，確認物件已上傳至 bucket。

```
gcloud storage ls gs://BUCKET_NAME
```

控制台應會列出 hello.txt 檔案。

4. 保護 Cloud Storage API

在上一個程式碼研究室中，我們建立了安全防護範圍，並保護 Compute Engine API。在本程式碼研究室中，我們將編輯 [模擬測試模式](#) 的 perimeter，並新增 Cloud Storage。這有助於我們判斷範圍保護措施的影響，因為稽核記錄會顯示 VPC Service Controls 違規事項，但資源仍可存取，直到我們強制執行範圍為止。

建立一般周邊時，系統也會自動建立模擬測試周邊。我們將在本實驗室中編輯這個檔案。

1. 在 Google 控制台中選取貴機構，然後 [存取 VPC Service Controls](#)。確認您位於機構範圍。
2. 開啟 Cloud Shell，並更新在上一個實驗室中建立的「SuperProtection」試營運安全防護範圍：

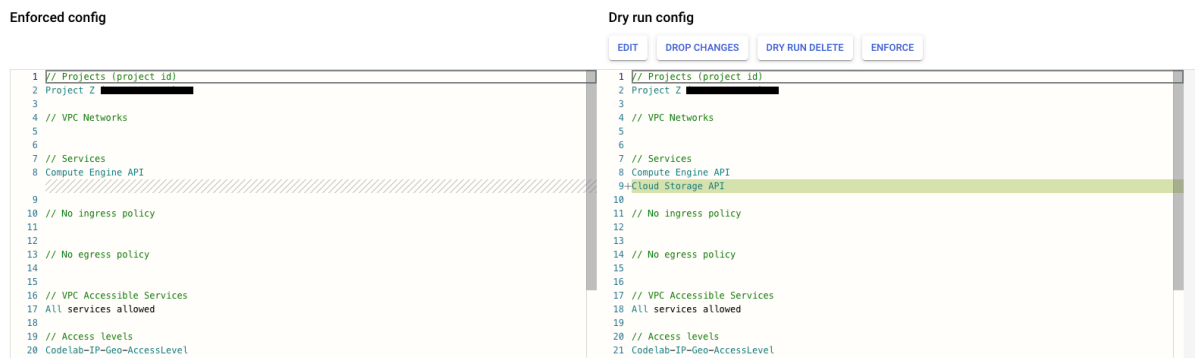
```
gcloud access-context-manager perimeters dry-run update SuperProtection --  
policy=POLICY --add-restricted-services=storage.googleapis.com
```

3. 說明安全範圍，確認 Cloud Storage API 已更新

```
gcloud access-context-manager perimeters dry-run describe SuperProtection --  
policy=POLICY
```

輸出內容會顯示 Cloud Storage API 列在受限服務下方

以及 Compute Engine API，但標籤為「`-vpcAccessibleServices: {}`」：



5. 確認 Cloud Storage API 已受到保護

在模擬測試模式中，從專案 Z 建立的 VM 執行個體列出物件到代管 Storage Bucket 的專案 X，確認「SuperProtection」安全防護範圍顯示拒絕存取

1. 在 Cloud 控制台中，前往專案選取器並選取 ProjectZ，然後依序前往「Compute Engine」>「VM 執行個體」。
2. 按一下「SSH」按鈕，連線至 VM 執行個體並存取其指令列。

VM instances

Filter

Enter property name or value

☐	Status	Name ↑	Zone	Recommendations	In use by	Internal IP	External IP	Labels	Connect
☐	✔	codelab-test-instance	us-central1-a	💡 Save \$12 / mo 💡 Save \$24 / mo				(nic0)	SSH ▾

3. 列出先前上傳的 hello.txt 檔案。

```
gcloud storage ls gs://BUCKET_NAME
```

由於 Cloud Storage API 在試執行模式下受到保護，您應該可以列出資源，但 ProjectZ 稽核記錄中必須有錯誤訊息。

4. 前往 ProjectZ 的 [Logs Explorer API](#)，然後尋找 VPC Service Controls 的最後一則錯誤訊息。您可以使用這個篩選器取得所需記錄：

```
protoPayload.status.details.violations.type="VPC_SERVICE_CONTROLS"
"(Dry Run Mode) Request is prohibited by organization's policy.
vpcServiceControlsUniqueIdentifier:UNIQUE_ID"
```

這個篩選器會顯示模擬測試模式中，屬於 Cloud Storage 的最後一次違規。以下範例說明記錄檔的樣子，以及嘗試列出 ProjectX 中 Bucket 的內容時，如何驗證違規事項是輸出違規事項。


```

egressViolations: [
0: {
servicePerimeter: "accessPolicies/POLICY/servicePerimeters/SuperProtection"
source: "projects/PROJECTX_ID"
sourceType: "Network"
targetResource: "projects/PROJECTZ_ID"
}
]
resourceNames: [
0: "projects//buckets/BUCKET_NAME"
]
securityPolicyInfo: {
organizationId: "ORGANIZATION_ID"
servicePerimeterName: "accessPolicies/POLICY/servicePerimeters/SuperProtection"
}
violationReason: "NETWORK_NOT_IN_SAME_SERVICE_PERIMETER"
vpcServiceControlsUniqueId: "UNIQUE_ID"
}
methodName: "google.storage.objects.list"

```

5. 由於我們已驗證對 Cloud Storage 的 API 呼叫會產生 VPC Service Controls 違規事項，因此將使用新設定強制執行範圍。開啟 Cloud Shell 並強制執行 Dry-run 邊界：

```

gcloud access-context-manager perimeters dry-run enforce SuperProtection --
policy=POLICY --async

```

6. 使用 SSH 連線至 VM 執行個體，然後再次列出儲存空間 bucket，確認已正確強制執行試執行安全防護範圍。

```

gcloud storage ls gs://BUCKET_NAME

```

我們會在 VM CLI 中收到 VPC Service Control 違規事項，而不是 Storage 物件清單：

```

ERROR: (gcloud.storage.ls) User [PROJECT_NUMBER-
compute@developer.gserviceaccount.com] does not have permission to access b instance
[BUCKET_NAME] (or it may not exist): Request is prohibited by organization's policy.
vpcServiceControlsUniqueIdentifier:"UNIQUE_ID"

```

我們已成功使用 VPC Service Controls 避免資料竊取，防止讀取或複製範圍外資源的資料。

6. 排解清單遭拒問題。

我們將排解從 VM 執行個體 CLI 取得的拒絕訊息。請檢查稽核記錄，找出 VPC Service Controls 專屬 ID。

1. 前往專案選取器，然後選取 ProjectZ。
2. 在 Logs Explorer 中使用下列查詢，找出稽核記錄中的 VPC Service Controls 專屬 ID：

```
resource.type="audited_resource"  
protoPayload.metadata["@type"]="type.googleapis.com/google.cloud.audit.VpcServiceControlAuditMetadata"
```

這會顯示所有 VPC Service Controls 稽核記錄。我們要尋找最後一個錯誤記錄。由於 API 呼叫是從 VM 執行個體發出，主體必須是 Compute Engine 服務帳戶「**PROJECT_NUMBER-compute@developer.gserviceaccount.com**」

由於我們已有 VPC Service Controls 專屬 ID，因此可以使用這個篩選條件，直接取得所需記錄：

```
protoPayload.metadata.vpcServiceControlsUniqueId="UNIQUE_ID"
```

3. 按一下「VPC Service Controls」標題，然後選取「Troubleshoot denial」(排解拒絕問題)，開啟 VPC Service Controls 疑難排解工具。

這個 API 會在友善的使用者介面中顯示違規原因，以及違規問題屬於輸入還是輸出類型等實用資訊。

在本練習中，我們將尋找下列內容：

```
authenticationInfo: {  
  principalEmail: "PROJECT_ID-compute@developer.gserviceaccount.com"  
  egressViolations: [  
    0: {  
      servicePerimeter: "accessPolicies/POLICY/servicePerimeters/SuperProtection"  
      source: "projects/PROJECTZ_ID"  
      sourceType: "Network"  
      targetResource: "projects/PROJECTX_ID"  
    }  
  ]  
  violationReason: "NETWORK_NOT_IN_SAME_SERVICE_PERIMETER"
```

我們只要有這項資訊，就能瞭解需要建立輸出規則，讓 Compute Engine 服務帳戶從 ProjectZ 存取 ProjectX 的儲存空間 bucket。此外，我們可以看到網路不在同一個範圍內，因此需要允許虛擬私有雲與服務通訊，並跨服務範圍共用資料。

4. 啟動 Cloud Shell，然後使用文字編輯器建立含有輸出規則的 .yaml 檔案。

```
nano egressstorage.yaml
```

```
- egressTo:
  operations:
    - serviceName: storage.googleapis.com
      methodSelectors:
        - method: \ "*\ "
  resources:
    - projects/PROJECTX_ID
egressFrom:
  identities:
    - serviceAccount:PROJECT_ID-compute@developer.gserviceaccount.com
```

5. [更新輸入政策](#)，保護 ProjectZ。

```
gcloud access-context-manager perimeters update SuperProtection --set-egress-
policies=egresstorage.yaml --policy=POLICY
```

現在可以再次嘗試從 VM 執行個體存取 bucket。

1. 在 Cloud 控制台中，前往專案選取器並選取 ProjectZ，然後依序前往「Compute Engine」>「VM 執行個體」。
2. 按一下「SSH」按鈕，連線至 VM 執行個體並存取其指令列。
3. 進入 VM CLI 後，請嘗試列出 Storage Bucket 中的物件。

```
gcloud storage ls gs://BUCKET_NAME/
```

您會收到下列錯誤訊息：

```
ERROR: (gcloud.storage.ls) User [PROJECT_ID-compute@developer.gserviceaccount.com]
does not have permission to access b instance [BUCKET_NAME] (or it may not exist):
PROJECT_ID-compute@developer.gserviceaccount.com does not have storage.objects.list
access to the Google Cloud Storage bucket. Permission 'storage.objects.list' denied
on resource (or it may not exist).
```

4. 我們需要授予 Compute Engine 服務帳戶 [物件讀取者權限](#)，才能列出 Storage Bucket 中的物件。

```
gcloud storage buckets add-iam-policy-binding gs://BUCKET_NAME --
member=serviceAccount:PROJECT_ID-compute@developer.gserviceaccount.com --
role=roles/storage.objectViewer
```

5. 再次嘗試從 VM 執行個體的 CLI 列出 hello.txt 檔案。

```
gcloud storage ls gs://BUCKET_NAME/
.
.
gs://BUCKET_NAME/hello.txt
```

現在我們可以在不違反 VPC Service Controls 權限的情況下列出物件，但[下載](#)檔案呢？我們試試看

```
gcloud storage cp gs://BUCKET_NAME/hello.txt /home/${USER}
```

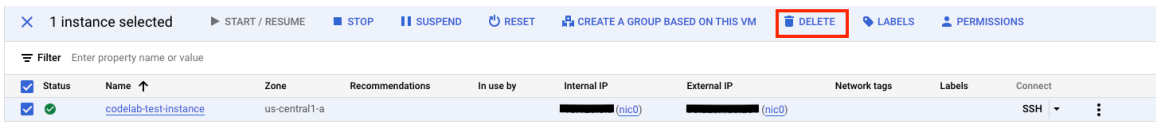
我們會得到下列輸出內容

```
Copying gs://BUCKET_NAME/hello.txt to file:///home/${USER}  
Completed files 1/1 | 54.0B/54.0B
```

7. 清除所用資源

雖然服務未使用時，使用 VPC Service Controls 無須另外付費，但建議您清理本實驗室中使用的設定。您也可以刪除 VM 執行個體和/或 Cloud 專案，以免產生費用。刪除 Cloud 專案後，系統就會停止對專案使用的所有資源收取費用。

1. 如要刪除 VM 執行個體，請選取 VM 執行個體名稱左側的核取方塊，然後按一下「Delete」(刪除)。



2. 如要刪除安全防護範圍，請完成下列步驟：

- 在 Google Cloud 控制台中，按一下「Security」(安全性)，然後在機構範圍內按一下「VPC Service Controls」。
- 在 VPC Service Controls 頁面中，找出要刪除的範圍，然後在對應的資料表列中按一下「刪除圖示」。

3. 如要刪除存取層級，請完成下列步驟：

- 在 Google Cloud 控制台中，開啟「Access Context Manager」頁面，並將範圍設為資料夾。
- 在表格中，在您要刪除的存取層級列中，按一下「刪除」圖示，然後按一下 **刪除**。

4. 如要刪除 Storage 物件和 Bucket，請完成下列步驟：

- 在 Google Cloud 控制台中，開啟 [Cloud Storage 值區頁面](#)。
- 找出您建立的值區，並選取旁邊的核取方塊。
- 按一下「刪除」。
- 在開啟的視窗中，確認要刪除 bucket。
- 按一下「刪除」。

5. 如要關閉專案，請完成下列步驟：

- 在 Google Cloud 控制台中，前往要刪除專案的「IAM 與管理設定」頁面。
 - 在「IAM & Admin Settings」(IAM 與管理設定) 頁面上，按一下「Shutdown」(關閉)。
 - 輸入專案 ID，然後點選「仍要關閉」。
-

步驟 8 · 約 0 分鐘

8. 恭喜！

在本程式碼研究室中，您更新了 VPC Service Controls 模擬測試範圍、強制執行範圍，並進行疑難排解。

瞭解詳情

- 請參閱 [VPC Service Controls 說明文件](#)。
- 請參閱 [Access Context Manager 說明文件](#)。
- 請參閱 [VPC-SC 疑難排解工具說明文件](#)。
- 請參閱「[輸入和輸出規則](#)」說明文件。
- 請參閱 [模擬執行說明文件](#)。
- 請參閱 [Cloud Storage 說明文件](#)。

授權

這項內容採用的授權為 創用 CC 姓名標示 2.0 通用授權。
